



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-33118 Microsoft Edge UI spoofing risk

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-04-10
Version	1.1
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-33118 Microsoft Edge UI spoofing risk - CVE / Vulnerability Threat Intelligence Report

Published: 2026-04-10 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-33118 Microsoft Edge UI spoofing risk

1. Executive Summary

CVE-2026-33118 is a spoofing vulnerability in Microsoft Edge (Chromium-based). Microsoft and the Microsoft CNA record classify the issue as `CWE-451: User Interface (UI) Misrepresentation of Critical Information`, meaning attacker-controlled content can cause Edge to present deceptive or misleading information to a victim.

The operational risk is primarily social-engineering enablement rather than code execution. Public sources show the issue carries a CVSS v3.1 base score of `4.3 / MEDIUM`, while Microsoft rates overall severity as `Low` and reports no public disclosure or in-the-wild exploitation at disclosure time. Edge versions earlier than `147.0.3912.60` are affected.

The 2026-06-08 MSRC intake item that triggered this review was not a new vulnerability disclosure. The feed summary states that Microsoft only updated an acknowledgement, so defenders should treat this as a documentation refresh for an April 2026 Edge patch rather than a newly emergent browser exploit.

2. Vulnerability Metadata

Field	Value
CVE	`CVE-2026-33118`
Product / component	`Microsoft Edge (Chromium-based)`
Vulnerability class	`Spoofing`
Weakness classification	`CWE-451: User Interface (UI) Misrepresentation of Critical Information`
CVSS v3.1	`4.3 / MEDIUM`
CVSS vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`
Microsoft aggregate severity	`Low`
Affected versions	Microsoft Edge (Chromium-based) earlier than `147.0.3912.60`
Fixed version	`147.0.3912.60`
Fixed-version release date in Microsoft material	`2026-04-10`
Underlying Chromium version listed by Microsoft for that release	`147.0.7727.55/.56`
Microsoft CNA publication date	`2026-04-10`
Microsoft CNA update date visible in the CVE record	`2026-06-01`
Acknowledged researcher listed in Microsoft CSAF	`nakanoou`

3. Source Review & Confidence

Source	Contribution	Confidence
Reviewed source	MSRC lists `CVE-2026-33118` as a Microsoft Edge (Chromium-based) spoofing vulnerability. The intake summary that trigger	Useful as the originating advisory and update reference, but richer technical details came from the

Reviewed source	Microsoft CSAF describes the issue as `CWE-451` UI misrepresentation in Microsoft Edge, rates aggregate severity `Low`,	Primary vendor technical source for severity, exploitability, fix version, FAQ context, and acknowledge
Reviewed source	The Microsoft CNA CVE 5.2 record describes Microsoft Edge (Chromium-based) spoofing, assigns `CWE-451`, records CVSS v3.	Primary authoritative vulnerability record for the affected-version range, CVSS data, and publicatio
Reviewed source	NVD mirrors the Microsoft description, CVSS v3.1 vector `AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`, `CWE-451`, and the vulner	Strong corroborating source for severity, vector, and affected-product metadata.
Reviewed source	Microsoft Edge security release notes state that Stable Channel version `147.0.3912.60` shipped on `2026-04-10` and expl	Strong corroborating source for patch timing and explicit linkage between the release and this CVE.
Reviewed source	ZDI's April 2026 Patch Tuesday review lists `CVE-2026-33118` as a Microsoft Edge (Chromium-based) spoofing vulnerability	Good third-party corroboration for severity and exploitation-status framing during disclosure week.

Confidence is high on the core facts because the reviewed primary sources align on the affected product, weakness type, attack preconditions, and patch version: Confidence is lower on exploitation prevalence because the reviewed public material does not show a proof of concept, CISA KEV inclusion, or confirmed in-the-wild abuse. The 2026-06-08 intake item appears to have been generated by an acknowledgement-only update, not a new technical revision to the vulnerability.

4. Vulnerability Details

Microsoft describes this issue as a spoofing vulnerability in Microsoft Edge caused by user-interface misrepresentation of critical information. In practical terms, an attacker can craft content that causes a victim to see misleading browser-controlled or browser-adjacent information, which can increase the chance that the victim trusts a fraudulent prompt, page state, or security cue.

The Microsoft FAQ text is useful for framing likely impact and attacker requirements:

- Successful exploitation can lead to limited confidentiality impact, not integrity or availability impact.
- User interaction is required.
- Microsoft states the interaction requirement as the attacker sending a malicious file that the victim would have to execute.

That wording is slightly unusual for a browser spoofing issue, but the combined Microsoft and NVD material still supports the core analyst conclusion that this is a deception-oriented vulnerability. Public sources reviewed for this intake do not support claims of arbitrary code execution, sandbox escape, or full device compromise from this CVE by itself.

5. Attack Scenarios

1. A threat actor delivers a phishing lure that convinces a victim to open attacker-controlled content in a vulnerable Edge build. Misleading UI elements increase the chance that the victim trusts false identity, payment, or account-security prompts.
2. A malicious or compromised website presents deceptive browser-context information to users running Edge versions earlier than `147.0.3912.60`, improving the believability of credential-harvesting or consent-phishing workflows.
3. A targeted intrusion campaign pairs this browser spoofing issue with branded SSO or cloud-service lures. The vulnerability does not directly steal credentials, but it can improve conversion rates for social-engineering operations.

4. Enterprise environments with unmanaged or delayed browser patching may face elevated phishing risk if users access sensitive SaaS or corporate portals from vulnerable Edge versions.

6. Threat Landscape & Exploitation Status

- Microsoft CSAF records exploit status as `Publicly Disclosed: No; Exploited: No`.
- The CISA ADP SSVC data embedded in the CVE 5.2 record reports `Exploitation: none`, `Automatable: no`, and `Technical Impact: partial`.
- ZDI's April 2026 Patch Tuesday review also lists `No` for both public disclosure and exploitation.
- User interaction is required, which reduces attacker reliability compared with silent browser exploitation chains.
- Business risk remains meaningful because browser spoofing vulnerabilities can materially improve phishing success, especially when users are rushed, working from unmanaged endpoints, or authenticating to high-value cloud services.

7. Affected Products and Exposure

The strongest supported exposure statement is that Microsoft Edge (Chromium-based) versions earlier than `147.0.3912.60` are affected.

Higher-risk exposure patterns:

- Organizations that allow Edge to access cloud identity, financial, or other sensitive workflows from endpoints with weak browser-version enforcement.
- User populations frequently targeted with phishing, credential-harvesting, or consent-phishing campaigns.
- Contractor, kiosk, lab, or lightly managed systems that may lag Edge updates.
- Privileged users who routinely follow links from email, chat, or support workflows.

Lower-risk exposure patterns:

- Environments that centrally enforce current Edge versions through enterprise management or rapid auto-update coverage.
- Workflows protected by phishing-resistant MFA, strict conditional-access controls, or browser isolation.
- User groups that do not use Microsoft Edge for sensitive workflows.

8. Mitigation and Workarounds

Priority actions:

5. Update Microsoft Edge to `147.0.3912.60` or later across managed endpoints.
6. Validate actual browser-version compliance through endpoint inventory, EDR, MDM, or software-asset tooling rather than assuming background updates succeeded.
7. Prioritize patch verification for high-value users who regularly access SSO, email, payments, or administrative consoles from Edge.
8. Reinforce anti-phishing training around deceptive login prompts, misleading browser states, and suspicious downloaded content.
9. Prefer phishing-resistant MFA where possible so spoofed or deceptive browser workflows have less downstream value.
10. Treat the 2026-06-08 MSRC acknowledgement update as informational only; patch urgency is tied to the April 2026 release, not to the later feed refresh.

9. Detection Engineering

There is no strong public exploit-signature set specific to this CVE. Detection should focus on exposure reduction and post-click telemetry:

Signal	Telemetry Source	Analytic Goal
Inventory endpoints running Microsoft Edge versions earlier than `147.0.3912.60`.	Asset inventory, SBOM, package management, CI/CD telemetry	Find vulnerable builds or packages

Correlate browser-version inventory with phishing alerts, suspicious downloads, and identity anomalies.	Asset inventory, SBOM, package management, CI/CD telemetry	Find vulnerable builds or packages
Review security telemetry for suspicious login attempts or MFA prompts that follow risky browsing activity on vulnerable Edge clients.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity
Where proxy, DNS, or secure web gateway telemetry is available, prioritize suspicious domains and redirect chains visited by systems that remained on vulnerable Edge builds after `2026-04-10`.	Asset inventory, SBOM, package management, CI/CD telemetry	Find vulnerable builds or packages
Monitor software-update or endpoint-management failures that delayed deployment of the April 2026 Edge stable release.	Asset inventory / service / security telemetry	Identify vulnerable systems, exposure, or suspicious follow-on activity

9.1 Detection Query

```
// Browser and mobile asset-version pivots for CVE-2026-33118 Microsoft Edge UI spoofing risk
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("edge", "msedge", "android", "adb shell dumpsys package", "winget list")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2026-33118 Microsoft Edge UI spoofing risk
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

10. Threat Hunting

Suggested hunt questions:

- Which endpoints still report Microsoft Edge versions earlier than `147.0.3912.60`?
- Which users accessed corporate identity providers, email, or sensitive SaaS workflows from those systems after `2026-04-10`?
- Are there recent phishing reports, suspicious downloaded files, or risky web sessions involving users who remained on vulnerable Edge versions?
- Do identity logs show suspicious authentication sequences shortly after browsing activity or downloaded-content execution on affected systems?
- Are unmanaged or infrequently connected assets lagging the April 2026 Edge stable update?

10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2026-33118 Microsoft Edge UI spoofing risk
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
```

```
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
| bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

11. MITRE ATT&CK Mapping

No ATT&CK technique is assigned with high confidence for this intake review. The reviewed public sources describe a browser UI spoofing condition that can support phishing or impersonation outcomes, but they do not document a concrete adversary procedure chain specific enough to justify a precise ATT&CK mapping without over-claiming.

12. Validation / Lab Testing

This intake review validated the report against published advisory, API, and release-history sources rather than reproducing the browser behavior locally. Analyst validation steps completed:

- Reviewed the MSRC Update Guide listing that triggered the intake.
- Parsed the Microsoft CSAF advisory for severity, exploitability, affected-version, remediation, FAQ, and acknowledgement details.
- Queried the Microsoft CNA CVE 5.2 record for authoritative affected-version, `CWE-451`, and CVSS data.
- Queried the NVD JSON 2.0 API for corroborating severity, vector, and affected-product metadata.
- Reviewed Microsoft Edge security release notes for the `147.0.3912.60` release date and explicit CVE listing.
- Reviewed ZDI's April 2026 Patch Tuesday summary for third-party corroboration of severity and exploitation status.

No Lost Boys Cyber proof-of-concept execution was performed as part of this intake review.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Platform / Application Owners	Patch Microsoft Edge to `147.0.3912.60` or later.
High	Security / Platform Owners	Verify version compliance through endpoint inventory rather than assuming auto-update coverage.
High	Security / Platform Owners	Prioritize users and systems exposed to phishing, downloaded-content execution, and cloud-identity workflows.
Critical	Platform / Application Owners	Hunt for suspicious authentication or phishing follow-on activity associated with systems that remained unpatched after `2026-04-10`.
High	Security / Platform Owners	Treat this issue as a phishing-risk multiplier and trust-deception problem rather than a direct code-execution vulnerability.

14. References

11. Microsoft Security Response Center, `CVE-2026-33118`
12. Microsoft CSAF advisory for `CVE-2026-33118`
13. CVE 5.2 record for `CVE-2026-33118` (Microsoft CNA)
14. NVD JSON 2.0 API for `CVE-2026-33118`

15. Microsoft Edge security release notes

16. Zero Day Initiative, `The April 2026 Security Update Review`